ENTERPRISE BACKEND REST API

Hospital Management System REST API

Complete Architecture, Integration & Operational Manual for Clinical, Inpatient, Pharmacy, and Administrative REST Web Services

FRAMEWORK & RUNTIME
Java 17 LTS / Spring Boot 3.3.4

SERVER PORT & PATH
Port 8085 (Context Path: /)

SECURITY & AUTHENTICATION
Stateless JWT (Bearer Authentication)

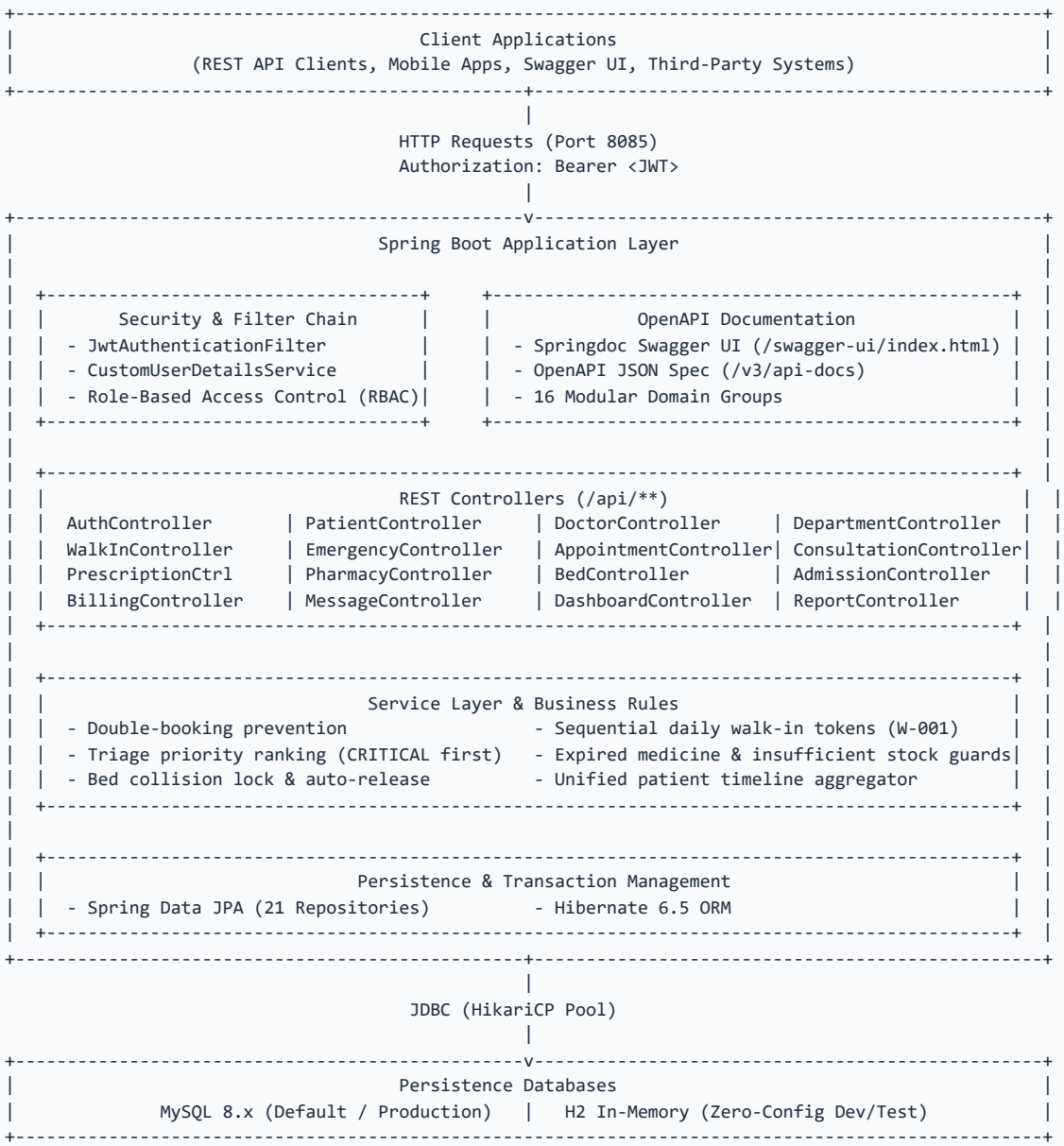
PERSISTENCE & DB
Spring Data JPA / Hibernate (MySQL 8 / H2)

INTERACTIVE DOCUMENTATION
Swagger UI (/swagger-ui/index.html)

DEFAULT ADMIN ACCOUNT
admin@hms.com / Admin@123

1. System Overview & Architecture

The **Hospital Management System REST API** is a high-performance, enterprise-grade backend service built from the ground up to support modern healthcare operations. The system eliminates all frontend dependencies, operating strictly as a headless RESTful backend designed for integration with web applications, mobile apps, telemetry devices, and enterprise hospital information systems.



Architectural Pillars

- **Port 8085**: Dedicated non-conflicting service port.
- **Stateless JWT Security**: Highly scalable token-based authentication.
- **Swagger UI**: Zero-UI backend with interactive OpenAPI explorer at `/swagger-ui/index.html`.
- **Production Grade**: Built with Bean Validation, Actuator health metrics, and comprehensive Mockito/JUnit 5 test suites.

Pre-Seeded Test Credentials

Role	Email	Password
ADMIN	`admin@hms.com`	`Admin@123`
DOCTOR	`dr.smith@lifecare.com`	`Doctor@123`
DOCTOR	`dr.sarah@lifecare.com`	`Doctor@123`
PATIENT	`jane.doe@example.com`	`Patient@123`

2. Security & Authentication Workflow

All sensitive hospital resources are guarded using **Spring Security 6** and **JJWT**. Unauthenticated requests to protected endpoints return `403 Forbidden`.

Authentication Flow

1. Client transmits credentials via `POST /api/auth/login`.
2. `CustomUserDetailsService` retrieves user record, verifies BCrypt hashed password.
3. `JwtTokenProvider` generates signed JWT (HMAC-SHA256) containing username, user ID, and assigned roles.
4. Client passes token in subsequent requests via HTTP header:

```
Authorization: Bearer eyJhbGciOiJIUzI1NiJ9...
```

5. `JwtAuthenticationFilter` intercepts incoming traffic, parses and validates claims, and populates `SecurityContextHolder`.

Role-Based Access Control (RBAC) Matrix

Domain / Operations	Public / Anonymous	Patient Role	Doctor Role	Admin Role
Authentication (Login, Register)	Full Access	Full Access	Full Access	Full Access
Patient Demographics & Profiles	No Access	Own Profile Only	Assigned / All	Full Access
Doctor Records & Rosters	Read List	Read List	Read & Profile Edit	Full Management
Walk-In Queue Registration	No Access	Register Walk-In	Call & Manage	Full Management
Emergency Department Intake	No Access	No Access	Triage & Treat	Full Management
Appointments	No Access	Book & View Own	Manage Doctor Slots	Full Management
Consultations & Prescriptions	No Access	View Own Prescriptions	Diagnose & Prescribe	Full Oversight
Pharmacy & Dispensing	No Access	No Access	View Stock Levels	Dispense & Manage
Inpatient Admissions & Beds	No Access	No Access	Admit & Discharge	Full Ward Allocation
Billing & Invoices	No Access	View Own Invoices	No Access	Generate & Pay
Dashboard & Executive Reports	No Access	No Access	No Access	Full Management

3. Three Major Hospital Workflows

Workflow 1: Walk-In Patient Queue Flow

Walk-in patients arrive at the outpatient department without scheduled appointments. The system handles arrival sequencing atomically.

- **Deterministic Daily Tokens**: Generates human-readable sequential tokens (`W-001` , `W-002` , `W-003` , ...) resetting at midnight.
- **Queue Progression Lifecycle**: `WAITING` → `CALLED` → `IN_CONSULTATION` → `COMPLETED` (or `CANCELLED`)
- **Department Filtering**: Live queue status viewable per department or hospital-wide.

Workflow 2: Emergency Clinical Triage Flow

Acute patients arriving at the emergency bay are triaged according to clinical acuity.

- **Acuity Ranking Hierarchy**: `CRITICAL` > `HIGH` > `MEDIUM` > `LOW`
- **Triage Sorting Invariant**: Active emergency queries (`GET /api/emergency/active`) always return `CRITICAL` patients first, sub-sorted by arrival timestamp.
- **Trauma Status Updates**: Transitions from `REGISTERED` → `TRIAGE` → `UNDER_TREATMENT` → `ADMITTED` or `DISCHARGED` .

Workflow 3: Appointment Booking & Conflict Guard

Prevents scheduling collisions and ensures doctors are never double-booked.

- **Double-Booking Invariant**: Before confirming a booking, `AppointmentServiceImpl` queries existing active bookings for that doctor at that specific date and time slot.
- **Collision Response**: If occupied, the request is immediately rejected with `DoubleBookingException` (HTTP 409 Conflict).
- **Appointment Lifecycle**: `PENDING` → `CONFIRMED` → `CHECKED_IN` → `IN_CONSULTATION` → `COMPLETED`

Inpatient Bed Lifecycle & Pharmacy Safety Rules

Bed Allocation & Release

- **Exclusive Allocation**: Assigning an already occupied bed throws `BedUnavailableException` (HTTP 400).
- **Admission State Transition**: On admission, bed is locked to `OCCUPIED`.
- **Discharge Auto-Release**: Processing patient discharge automatically returns bed to `AVAILABLE`.

Pharmacy Dispensing Rules

- **Expiry Verification**: Medications with `expiryDate < today` are rejected with `ExpiredMedicineException`.
- **Stock Invariant**: Requests exceeding available quantity throw `InsufficientStockException`.
- **Atomic Stock Decrement**: Transactions occur inside `@Transactional` boundaries.

4. REST API Endpoint Reference (16 Domains)

1. Authentication (`/api/auth/**`)

POST `/api/auth/register` — Register new patient account

Request Body:

```
{
  "firstName": "Jane",
  "lastName": "Doe",
  "email": "jane.doe@example.com",
  "password": "Password@123",
  "phone": "9876543210",
  "dateOfBirth": "1995-05-15",
  "gender": "Female",
  "bloodGroup": "O+",
  "emergencyContact": "9123456789"
}
```

Response: `201 Created` — `AuthResponse` containing JWT token and registered patient details.

POST `/api/auth/login` — User authentication (All Roles)

Request Body:

```
{
  "email": "admin@hms.com",
  "password": "Admin@123"
}
```

Response: `200 OK` — `{ "success": true, "token": "...", "user": { "id": 1, "email": "admin@hms.com", "role": "ADMIN" } }`

GET `/api/auth/me` — Current user profile

Headers: `Authorization: Bearer <token>` — Returns authenticated user object.

2. Patients (`/api/patients/**`)

Method	Path	Role	Description
GET	`/api/patients`	ADMIN DOCTOR	Paginated/filtered list of all patients
GET	`/api/patients/{id}`	ADMIN DOCTOR PATIENT	Patient profile by ID
POST	`/api/patients`	ADMIN	Create new patient profile
PUT	`/api/patients/{id}`	ADMIN	Update medical history, allergies, demographics
GET	`/api/patients/{id}/medical-history`	ADMIN DOCTOR PATIENT	Aggregated medical timeline (Admissions, Consultations, Rx, Invoices)

3. Doctors (`/api/doctors/**`)

Method	Path	Role	Description
GET	`/api/doctors`	PUBLIC	List all active doctors with specialization
GET	`/api/doctors/{id}`	PUBLIC	Get doctor profile, qualification, consultation fee
GET	`/api/doctors/department/{id}`	PUBLIC	Filter doctors by department ID
POST	`/api/doctors`	ADMIN	Register new doctor with medical license
PUT	`/api/doctors/{id}/status`	ADMIN DOCTOR	Update status (`AVAILABLE` , `BUSY` , `ON_LEAVE` , `INACTIVE`)

4. Departments (`/api/departments/**`)

Method	Path	Role	Description
GET	`/api/departments`	PUBLIC	List all hospital clinical departments
GET	`/api/departments/{id}`	PUBLIC	Get department details
POST	`/api/departments`	ADMIN	Add new department (e.g. Cardiology, Neurology)
PUT	`/api/departments/{id}`	ADMIN	Update department status and description

5. Walk-In Queue (`/api/walk-ins/**`)

POST **`/api/walk-ins`** Register walk-in arrival

Request Body:

```
{
  "patientId": 1,
  "departmentId": 2,
  "doctorId": 1,
  "visitReason": "Chest pain and fatigue",
  "priority": "HIGH"
}
```

Response: Returns generated token (e.g., `"tokenNumber": "W-001"`) and status `WAITING` .

Method	Path	Role	Description
GET	`/api/walk-ins/today`	ADMIN DOCTOR	List today's walk-in arrivals
GET	`/api/walk-ins/department/{id}/queue`	ADMIN DOCTOR	Department active queue
PUT	`/api/walk-ins/{id}/status`	ADMIN DOCTOR	Update status (`WAITING` , `CALLED` , `COMPLETED`)

6. Emergency Cases (`/api/emergency/**`)

`POST` **`/api/emergency`** — Register acute emergency triage

Request Body:

```
{
  "patientId": 1,
  "chiefComplaint": "Motor vehicle collision, respiratory distress",
  "emergencyCondition": "Multiple trauma",
  "priority": "CRITICAL",
  "assignedDoctorId": 2,
  "departmentId": 1,
  "bloodPressure": "85/55",
  "heartRate": 130,
  "oxygenSaturation": 88.5,
  "temperature": 37.8,
  "respiratoryRate": 28
}
```

Method	Path	Role	Description
`GET`	`/api/emergency/active`	`ADMIN` `DOCTOR`	Active emergencies sorted by triage severity (`CRITICAL` first)
`PUT`	`/api/emergency/{id}/triage`	`DOCTOR`	Update triage severity level
`PUT`	`/api/emergency/{id}/status`	`DOCTOR`	Update status (`UNDER_TREATMENT` , `ADMITTED` , `DISCHARGED`)

7. Appointments (`/api/appointments/**`)

Method	Path	Role	Description
`POST`	`/api/appointments`	`PATIENT` `ADMIN`	Book slot (intercepts double-bookings with 409 Conflict)
`GET`	`/api/appointments/doctor/{id}`	`DOCTOR` `ADMIN`	Doctor's booked consultation schedule
`GET`	`/api/appointments/patient/{id}`	`PATIENT` `ADMIN`	Patient's appointment history
`PUT`	`/api/appointments/{id}/status`	`DOCTOR` `ADMIN`	Update status (`CONFIRMED` , `CHECKED_IN` , `COMPLETED`)
`DELETE`	`/api/appointments/{id}`	`PATIENT` `ADMIN`	Cancel scheduled appointment

8. Consultations & 9. Prescriptions

Consultations (`/api/consultations/**`)

- `POST /api/consultations` — Record clinical diagnosis, vitals, symptoms, follow-up date.
- `GET /api/consultations/{id}` — Consultation report.
- `GET /api/consultations/patient/{id}` — Patient consultation history.

Prescriptions (`/api/prescriptions/**`)

- `POST /api/prescriptions` — Issue e-prescription with medication items, dosage, and duration.
- `GET /api/prescriptions/{id}` — Detailed digital prescription.
- `GET /api/prescriptions/patient/{id}` — Patient prescription records.

10. Pharmacy & Inventory (`/api/inventory/**` & `/api/pharmacy/**`)

POST **/api/pharmacy/sales** — Dispense medications & update stock

Request Body:

```
{
  "patientId": 1,
  "prescriptionId": 1,
  "paymentMethod": "CASH",
  "items": [
    { "medicineId": 1, "quantity": 2, "unitPrice": 15.00 },
    { "medicineId": 2, "quantity": 1, "unitPrice": 45.00 }
  ]
}
```

Validation Rules: Rejects expired batches (`ExpiredMedicineException`) and quantities exceeding stock (`InsufficientStockException`).

Method	Path	Role	Description
GET	`/api/inventory`	ADMIN	Full medicine stock catalog
POST	`/api/inventory`	ADMIN	Add new medicine batch with expiry and price
GET	`/api/inventory/low-stock`	ADMIN	Alert items below minimum stock threshold
GET	`/api/inventory/expired`	ADMIN	List expired medicine inventory

11. Beds & 12. Inpatient Admissions

Method	Path	Role	Description
GET	`/api/wards`	ADMIN	List all hospital wards (General, ICU, Emergency, Private)
GET	`/api/beds/available`	ADMIN DOCTOR	Find beds ready for patient allocation
POST	`/api/admissions`	DOCTOR ADMIN	Admit patient; sets target bed to `OCCUPIED`
GET	`/api/admissions/active`	ADMIN DOCTOR	List currently admitted inpatients
PUT	`/api/admissions/{id}/discharge`	DOCTOR ADMIN	Discharge patient; automatically frees bed to `AVAILABLE`

13. Billing & Invoicing (`/api/billing/**`)

Method	Path	Role	Description
POST	`/api/billing/invoices`	ADMIN	Generate itemized invoice (Consultation, Room, Medicine, Diagnostics)
GET	`/api/billing/invoices/{id}`	ADMIN PATIENT	Fetch invoice details with calculated subtotal, tax, and discount
POST	`/api/billing/invoices/{id}/payments`	ADMIN	Record payment (`CASH` , `CARD` , `UPI` , `INSURANCE`)

14. Messaging, 15. Dashboard & 16. Reports

Method	Path	Role	Description
POST	`/api/messages`	PUBLIC	Send feedback or inquiry linked to department
GET	`/api/messages`	ADMIN	List all messages (supports mark-as-read)
GET	`/api/dashboard/summary`	ADMIN	Executive metrics: active patients, doctors, beds, alerts
GET	`/api/reports/revenue`	ADMIN	Financial revenue analytics filtered by date range
GET	`/api/reports/bed-occupancy`	ADMIN	Inpatient bed occupancy rates by ward

5. Execution, Testing & Health Verification

Running the Application

In-Memory Mode (Zero Database Setup - Fast Evaluation):

```
java -jar target/hospital-backend-1.0.0.jar --spring.profiles.active=h2
```

Production Mode (MySQL 8.x):

```
$env:DB_HOST="localhost"; $env:DB_PORT="3306"; $env:DB_NAME="lifecare_hospital"; $env:DB_USERNAME="ro
```

Automated Test Suite Verification (JUnit 5 + Mockito)

Execute tests from the repository root:

```
mvn test
```

Test Suite Class	Tests	Result	Key Validations
`LifeCareHospitalApplicationTests`	1	**PASS**	Spring context bootstrap, Hibernate schema setup, `DataInitializer` seeding.
`SecurityAuthorizationTest`	3	**PASS**	Anonymous access rejected (403), patient role denied admin APIs (403), admin allowed (200).
`HospitalWorkflowsServiceTest`	8	**PASS**	Double-booking prevention, daily token generation (`W-006`), emergency triage sorting (`CRITICAL` first), expired medicine rejection, stock checks, bed locking and release.

Interactive OpenAPI (Swagger UI) Access

Live Swagger UI URL: http://localhost:8085/swagger-ui/index.html
Raw OpenAPI JSON: http://localhost:8085/v3/api-docs
Actuator Health Endpoint: http://localhost:8085/actuator/health